

Red team report: pentesting de My File Server 1

Ojeda Camacho José Carlos / 181629



Evaluación Estratégica de Ciberseguridad: My File Server 1

- Red Team Report - Actividad 13
 - Presenta: José Carlos Ojeda Camacho | Consultor de Ciberseguridad Estratégica
 - Fecha: Octubre 2026
-

Contexto del Engagement

- Objetivo: Simular un ataque cibernético del mundo real contra el servidor central de archivos ("My File Server 1") para evaluar la postura de seguridad.
- Alcance: Evaluación controlada de los servicios de red expuestos y la robustez de las configuraciones del sistema.
- Valor para el Negocio: Identificar vulnerabilidades críticas antes de que actores maliciosos puedan explotarlas, protegiendo los activos más valiosos.

Metodologia Aplicada

Inteligencia: Mapeo de la superficie expuesta sin afectar la operación.

Análisis: Identificación de brechas de seguridad y configuraciones deficientes.

Validación: Explotación controlada para demostrar el impacto real.

Valoración: Traducción de hallazgos técnicos a riesgos de negocio.

Nivel General del Riesgo

- **Nivel de Riesgo: CRÍTICO** (Destacar en color rojo o con un medidor visual de riesgo al máximo).
- **Veredicto Ejecutivo:** El sistema fue comprometido en su totalidad. Un atacante externo sin privilegios iniciales puede obtener control administrativo absoluto del servidor en cuestión de minutos.
- **Estado de la Información:** Altamente vulnerable a robo, alteración o secuestro (Ransomware).

Hallazgos Criticos

Fuga de Credenciales (Alta): Contraseñas corporativas almacenadas en documentos de texto públicos sin ningún tipo de protección o cifrado.

Controles de Acceso Deficientes (Media): Carpetas de red compartidas con permisos de lectura y escritura abiertos a usuarios no autorizados.

Obsolescencia del Sistema Core (Crítica): El núcleo del servidor carece de actualizaciones críticas de seguridad, permitiendo que un usuario de bajo perfil se convierta en administrador absoluto del sistema.

Escenario del Impacto Empresarial



Pérdida de Confidencialidad: Exposición de propiedad intelectual, datos financieros y registros de clientes (riesgo de multas regulatorias y daño reputacional).



Violación de Integridad: Capacidad de un atacante para modificar registros contables, alterar contratos o instalar puertas traseras indetectables.



Interrupción de Disponibilidad: Riesgo inminente de parálisis operativa. El atacante posee los permisos necesarios para borrar bases de datos enteras o cifrar el servidor exigiendo un rescate económico.

Matriz de Riesgo

- **VULN-01:** Fuga de Credenciales (Texto Claro)
- **VULN-02:** Controles de Acceso Deficientes (SMB)
- **VULN-03:** Obsolescencia del Sistema Core (DirtyCow)

5					
4	VULN-02		VULN-01		
3					
2					VULN-03
1					
	1	2	3	4	5

Recomendaciones Estratégicas

- **Modernización y Parcheo (Patch Management):** Autorizar un ciclo de mantenimiento urgente para actualizar los sistemas operativos obsoletos en toda la infraestructura.
- **Cultura de Cero Confianza (Zero Trust):** Implementar el principio de "mínimo privilegio". Ningún usuario debe tener más acceso del estrictamente necesario para su rol.
- **Gestión de Secretos:** Establecer políticas estrictas que prohíban el almacenamiento de contraseñas en texto claro, apoyadas por auditorías automatizadas.

Roadmap de Remediacion

Inmediato (24 - 48 horas):

Eliminar archivos públicos con contraseñas.
Restringir accesos de lectura/escritura en red.



Corto Plazo (1 - 2 semanas):

Aplicar actualizaciones críticas al núcleo del servidor.
Rotar todas las contraseñas comprometidas.



Mediano Plazo (1 - 3 meses):

Implementar un sistema de monitoreo continuo.
Programar pruebas de penetración recurrentes.



Conclusion Ejecutiva

En conclusión, la evaluación de seguridad realizada a "My File Server 1" demostró de manera contundente que la combinación de configuraciones deficientes, como la exposición pública de credenciales en texto claro, junto con la obsolescencia crítica del sistema operativo, resulta inevitablemente en un compromiso total de la infraestructura. Este ejercicio evidencia que vulnerabilidades que podrían parecer aisladas pueden ser encadenadas por un atacante para escalar privilegios y obtener control administrativo absoluto (root), subrayando la urgencia corporativa de implementar un ciclo riguroso de gestión de parches, endurecer los controles de acceso bajo el principio de mínimo privilegio y establecer políticas estrictas para la protección de secretos, garantizando así la resiliencia y la continuidad operativa del negocio frente a amenazas reales.

